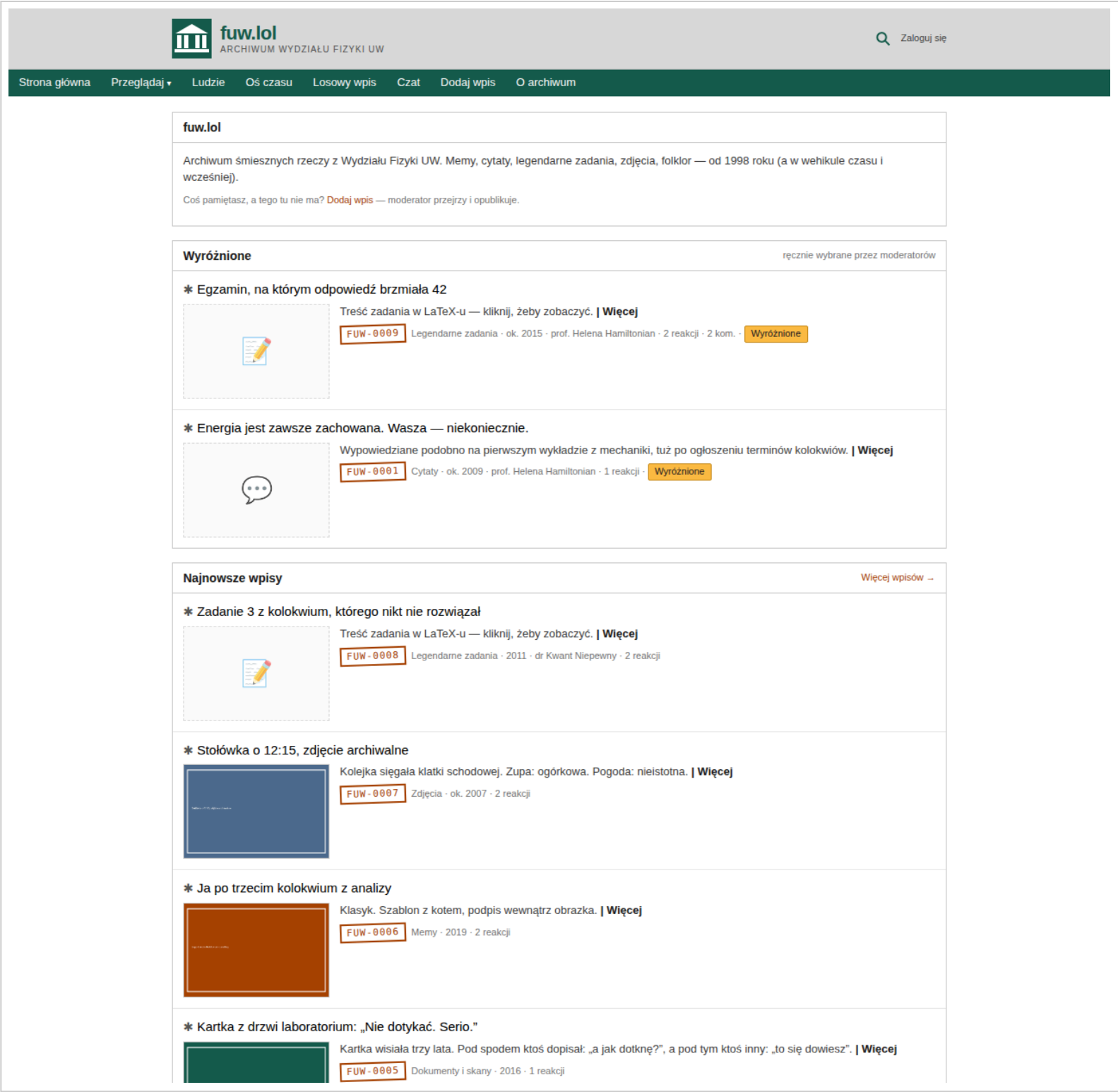


fuw.lol

Nieoficjalne, społecznościowe archiwum śmiesznych rzeczy z Wydziału Fizyki UW — memy, cytaty, legendarne zadania, zdjęcia, folklor, stare strony.

- **Stos:** Django 5.2 + Django REST Framework (Postgres / SQLite lokalnie, tokeny) · SvelteKit 2 / Svelte 5 (SPA, adapter-static) · LaTeX.js + KaTeX w przeglądarce · marked + DOMPurify.
- **Wdrożenie:** Hetzner + Coolify + Cloudflare, trzy kontenery (Postgres, Django/gunicorn, nginx ze zbudowaną aplikacją).
- **Wygląd** celowo kopiuje www.fuw.edu.pl (Tahoma 13 px, zielony pasek #175e4c, ramki 1 px #ccc, * przed nagłówkami) — to część żartu.
- **Ten dokument:** architektura, model danych, role, cykl życia wpisu, zaufani i tablica moderacji, eskalacja do NASK, czat, wehikuł czasu, bezpieczeństwo (po przeglądzie z 16.09.2026), wdrożenie, testy i analiza przepływów z rekomendacjami.

Zrzuty ekranu pochodzą z działającej instancji deweloperskiej z treścią demo (postacie są fikcyjne). Stan na 17.09.2026.

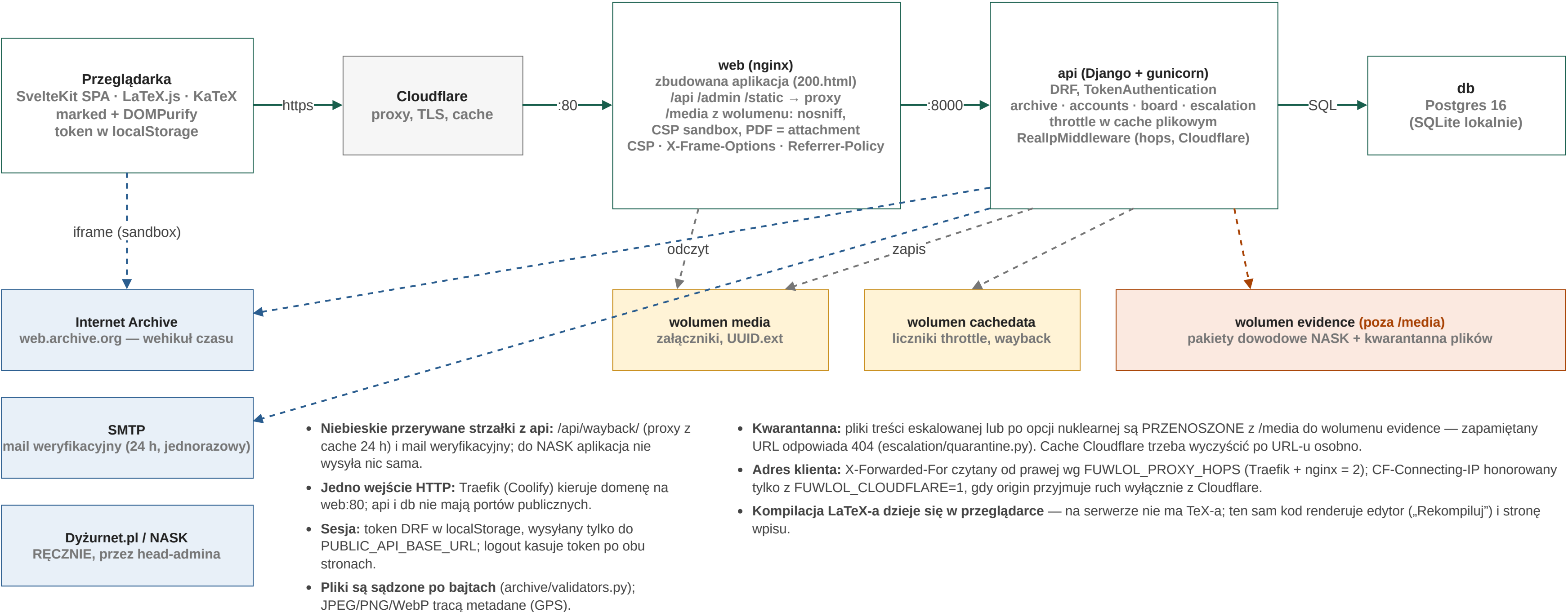


Wszystkie strony i to, kto je widzi

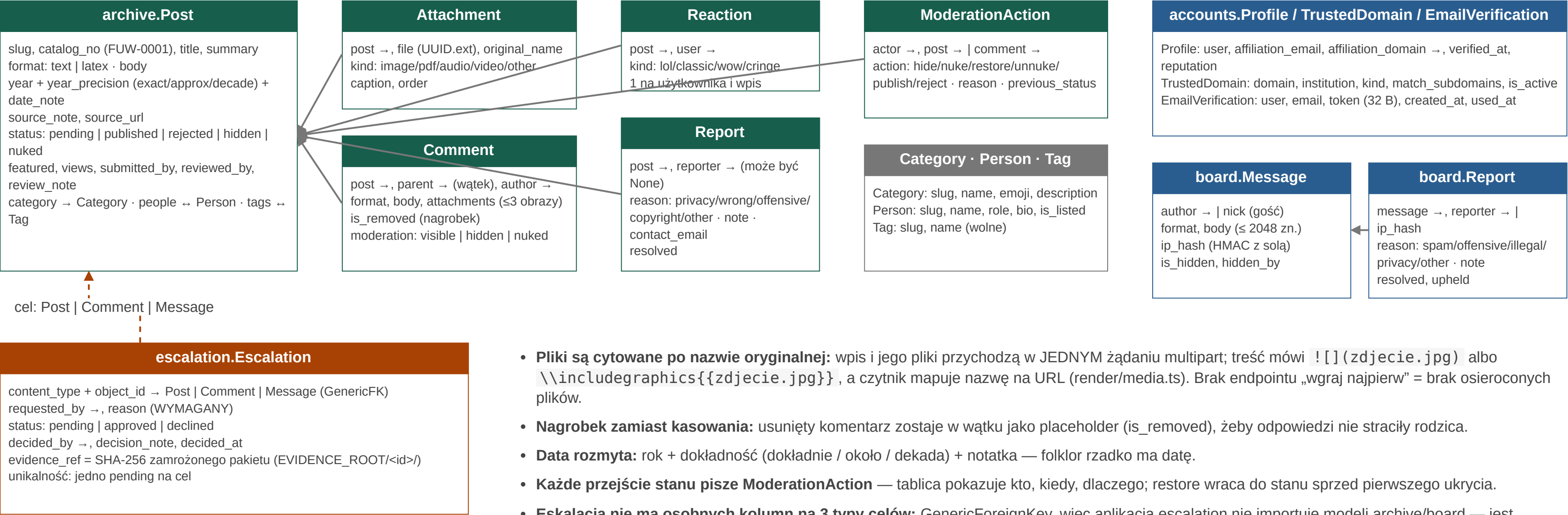
Każdy (bez konta)	Zalogowany	Zaufany (adres FUW/UW/PAN)	Administracja (is_staff)	Head-admin (superuser)
Strona główna /	Dodaj wpis → kolejka /dodaj	Publikuje od ręki /dodaj	Kolejka + zgłoszenia /moderacja	Decyzje NASK /eskalacje
Przeglądaj + szukaj /przegladaj	Edycja własnego wpisu /edytuj/[slug]	Ukryj · przywróć wpis / czat	Odnukearnij, wyróżnij wpis	Widzi także treści eskalowane /admin/
Wpis /wpis/[slug]	Moje wpisy + statusy /moje	☢ Opcja nuklearna wpis / czat	Panel Django /admin/	
Osoby folkloru /ludzie, /ludzie/[slug]	Weryfikacja afiliacji /konto	Tablica moderacji /tablica		
Oś czasu /os-czasu	Potwierdzenie adresu /potwierdz?token=	🚨 Zgłoś do NASK wpis / czat		
Losowy wpis /losowe	Reakcje, komentarze, zgłoszenia wpis			
Czat (pisze każdy) /czat				
O archiwum /o-archiwum				
Konto /logowanie, /rejestracja				
Wehikuł czasu /?czas=...				

Każdy wyższy poziom dziedziczy wszystko z niższych. Staff jest zawsze zaufany. Uprawnienia rozstrzyga ZAWSZE backend (archive/moderation.py, escalation/visibility.py) — frontend tylko chowa przyciski.

Przeglądarka → Cloudflare → nginx → Django → Postgres; pliki na wolumenie, dowody poza nim



backend/archive · accounts · board · escalation



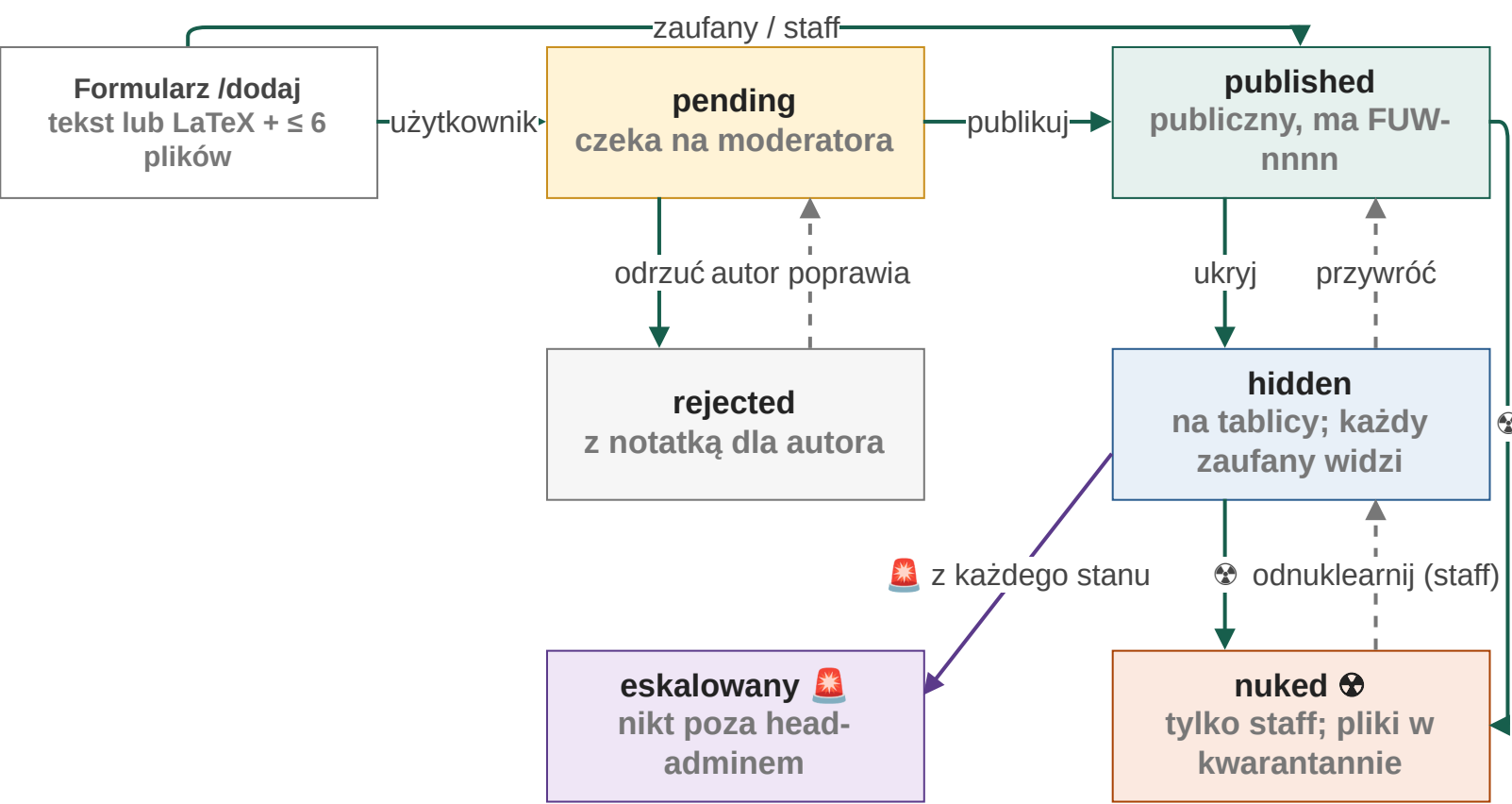
- **Pliki są cytowane po nazwie oryginalnej:** wpis i jego pliki przychodzą w JEDNYM żądaniu multipart; treść mówi `` albo `\\includegraphics{{zdjecie.jpg}}`, a czytelnik mapuje nazwę na URL (`render/media.ts`). Brak endpointu „wgraj najpierw” = brak osieroconych plików.
- **Nagrobek zamiast kasowania:** usunięty komentarz zostaje w wątku jako placeholder (`is_removed`), żeby odpowiedzi nie straciły rodzica.
- **Data rozmyta:** rok + dokładność (dokładnie / około / dekada) + notatka — folklor rzadko ma datę.
- **Każde przejście stanu pisze ModerationAction** — tablica pokazuje kto, kiedy, dlaczego; restore wraca do stanu sprzed pierwszego ukrycia.
- **Eskalacja nie ma osobnych kolumn na 3 typy celów:** GenericForeignKey, więc aplikacja escalation nie importuje modeli archive/board — jest liściem, o który pytają inni.

Kto może co — jedna tabela, backend jest jej źródłem prawdy

Czynność	Gość	Użytkownik	Zaufany	Staff	Head-admin
Czytanie opublikowanych wpisów, osób, osi czasu, czatu, RSS	✓	✓	✓	✓	✓
Pisanie na czacie (nick gościa ≠ istniejący login)	✓	✓	✓	✓	✓
Zgłoszenie wpisu / wiadomości (także anonimowo: „dotyczy mnie”)	✓	✓	✓	✓	✓
Dodanie wpisu → kolejka moderacji	—	✓	od ręki	od ręki	od ręki
Edycja własnego wpisu (pending/rejected/published → wraca do kolejki)	—	✓	✓	✓	✓
Reakcje, komentarze (tekst / LaTeX, ≤ 3 obrazy)	—	✓	✓	✓	✓
Ukryj / przywróć wpis, komentarz, wiadomość; tablica moderacji	—	—	✓	✓	✓
☢ Opcja nuklearna (powód wymagany); cofnięcie	—	—	tylko nałożyć	✓	✓
Kolejka moderacji: publikuj / odrzuć / wyróżnij; panel Django	—	—	—	✓	✓
🚨 Zgłoś do NASK (treść znika dla wszystkich, także staff)	—	—	✓	✓	✓
Decyzja NASK (zatwierdź / odrzuć), wgląd w dowody, treści eskalowane	—	—	—	—	✓
Widzi treść po opcji nuklearnej	—	—	tylko stub	✓	✓
Widzi e-mail i notatkę zgłaszającego	—	—	tylko powód	✓	✓

- **Zaufany** = konto z potwierdzonym adresem w domenie z tabeli TrustedDomain (fuw.edu.pl, uw.edu.pl, student.uw.edu.pl, instytuty PAN...). Dopasowanie ściśle: lowercase ASCII, jedno @, subdomeny tylko tam, gdzie wiersz na to pozwala; `x@fuw.edu.pl.evil.com` nie przechodzi.
- **Staff** = Django `is_staff`. **Head-admin** = `is_superuser` — jedyny poziom, na którym „staff” przestaje cokolwiek znaczyć (`escalation/visibility.py`). Nadawaj go jak najmniejszej liczbie osób.
- **Reputacja** (`Profile.reputation`): +1 gdy moderator potwierdzi ukrycie, do którego przyczyniło się Twoje zgłoszenie, −1 gdy je cofnie. Jeszcze niczego nie blokuje — jest zapisem, nie dźwignią.

Od formularza do archiwum — i z powrotem, jeśli trzeba



Dodaj wpis do archiwum
Wpis trafi do moderacji, moderatorzy publikują od ręki.

Dane wpisu

Tytuł *
np. Kartka na drzwiach dziekanatu, 2009

Kategoria *
— wybierz —

Rok
np. 2009

Dokładność daty
około

Notatka o dacie
np. semestr zimowy 2009, kolokwium II

Osoby
☐ dr Kwant Niepewny — postać fikcyjna — wykładowca mechaniki kwantowej
☐ Pani z portierni — postać fikcyjna — insygnacja
☐ prof. Helena Hamiltonian — postać fikcyjna — mechanika klasyczna

Brak osoby? Wpisz ją w tagach.

Tagi (po przecinku)
np. kolokwium, kreda, dziekanat

Źródło
np. zdjęcie od autora, archiwum SKFiz

Link źródła
np. fuw.edu.pl/aktualnosci

Streszczenie
Puste — wypełnimy je początkiem treści. 0/300

Pliki
Dodaj pliki
Choose Files
No file chosen
Obrazy, PDF, audio, wideo, bit, tex — do 25 MB każdy. Spacje w nazwach zamieniamy na myślniki, bo wpis odwokuje się do plików po nazwie.
Na razie bez plików.

Treść wpisu

Tekst + obrazy
LaTeX (jak Overleaf)

Napisz, co się stało...

Podgląd
Podgląd pojawi się, gdy zaczniesz pisać.

Kolejka moderacji
1 do przejścia

FUV-0010 Propozycja: nowy mem o sesji Czekaj na moderację

student · dodano 12 września 2026 · Memy · 2026 · Tekst
Pokaż podgląd treści

Notatka moderatora (trafia do autora)

Opublikuj Odrzuć Ukryj Wyróżnij

/moderacja — kolejka: publikuj / odrzuć / ukryj / wyróżnij

Moje wpisy
5 wpisów

Mem, który był trochę za bardzo
FUV-0011 · Memy · 2022 · dodano 12 września 2026
Ukryty Edytuj

Propozycja: nowy mem o sesji
FUV-0010 · Memy · 2026 · dodano 12 września 2026
Czekaj na moderację Edytuj

Stołówka o 12:15, zdjęcie archiwalne
FUV-0007 · Zdjęcia · ok. 2007 · dodano 12 września 2026
Opublikowany Edytuj

Hymn kolejki do dziekanatu
FUV-0003 · Folklor · ok. 1998 · dodano 12 września 2026
Opublikowany Edytuj

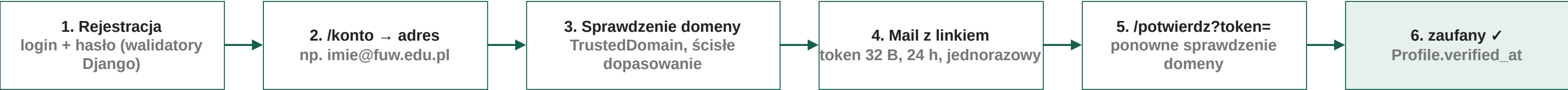
Energia jest zawsze zachowana. Wasza — niekoniecznie.
FUV-0001 · Cyfaty · ok. 2009 · dodano 12 września 2026
Opublikowany Edytuj

/moje — autor widzi status każdego swojego wpisu

- **Numer katalogowy** FUV-nnnn nadawany przy pierwszej publikacji; nie zmienia się przy ukryciu i przywróceniu.
- **Odrzucony wpis** autor może poprawić — edycja wraca do kolejki. Notatka moderatora jest widoczna tylko dla autora i staff (poprawka z przeglądu 16.09).
- **Edycja opublikowanego wpisu** przez zwykłego użytkownika też wraca do kolejki; zaufany i staff edytują w miejscu.
- **Każda strzałka pisze ModerationAction** (kto, kiedy, powód, stan poprzedni); „przywróć” czyta ten dziennik, żeby wrócić do stanu sprzed pierwszego ukrycia — nigdy prosto do „published”, jeśli wpis nie był zatwierdzony.
- **Limity**: 30 wpisów/h na konto, 25 MB na plik, 6 plików; komentarze 60/h (nowy limit).

/dodaj — dane wpisu, pliki, treść z podglądem

Potwierdzony adres instytucjonalny daje narzędzia moderacji — bez kolejki i bez etatu



- **Dlaczego adres, a nie prośba do admina:** członkostwo w społeczności jest sprawdzalne bez etatu moderatora — a to właśnie moderator jest wąskim gardłem takiego archiwum.
- **Co daje status zaufanego:** wpisy publikują się od ręki; ukrywanie jednym kliknięciem (treść trafia na tablicę, gdzie każdy zaufany może ją przywrócić); opcja nuklearna dla treści nielegalnych lub obrzydliwie obraźliwych; zgłoszenie do NASK.
- **Czego nie daje:** kolejki moderacji, cofnięcia opcji nuklearnej, wglądu w e-mail zgłaszającego, decyzji NASK.
- **Adres służy tylko do weryfikacji** — nie jest pokazywany nikomu; w API wraca zamaskowany (j***@fuw.edu.pl). Domena może zostać wyłączona w panelu — wtedy is_trusted gaśnie, choć afiliacja pozostaje zapisana.
- **Limity:** 5 maili/h na konto; logowanie 20/min na adres IP i 10/min na login (nowe — przeciw rozproszonemu zgadywaniu hasła jednego konta).
- **Zostawione otwarte:** brak resetu hasła (nie ma jeszcze maili poza weryfikacją); brak blokady konta po n nieudanych próbach — throttle liczy próby, nie porażki.

Twoje konto

student

E-mail konta

student@fuw.lol

Rola

zwykły użytkownik

Moje wpisy

Weryfikacja afiliacji

wyższe uprawnienia dla ludzi z Wydziału i okolic

Potwierdź adres e-mail w domenie związanej z Wydziałem Fizyki (UW, studenci UW, CeNT, instytuty PAN), a dostaniesz status **zaufanego**: twoje wpisy publikują się od ręki, możesz jednym kliknięciem ukrywać treści (trafiają na **tablicę moderacji**, gdzie widzą je wszyscy zaufani) i — w ostateczności — użyć opcji nuklearnej dla treści nielegalnych lub obrzydliwie obraźliwych (wtedy widzi je już tylko administracja).

Adres instytucjonalny

imie.nazwisko@fuw.edu.pl

Adres służy tylko do weryfikacji — nie pokażemy go nikomu.

Wyślij link weryfikacyjny

Akceptowane domeny: camk.edu.pl (CAMK PAN), cent.uw.edu.pl (CeNT UW), cft.edu.pl (Centrum Fizyki Teoretycznej PAN), ichf.edu.pl (IChF PAN), ifpilm.pl (IFPiLM), ippt.pan.pl (IPPT PAN), ifpan.edu.pl (Instytut Fizyki PAN), unipress.waw.pl (Instytut Wysokich Ciśnień PAN), ncbj.gov.pl (NCBJ), astrouw.edu.pl (Obserwatorium Astronomiczne UW), student.uw.edu.pl (Studenci UW), uw.edu.pl (Uniwersytet Warszawski), fuw.edu.pl (Wydział Fizyki UW).

/konto — weryfikacja afiliacji z listą akceptowanych domen

Wszystko, co zniknęło ze strony publicznej — z podpisem, datą i powodem

Tablica moderacji

Tu leży wszystko, co zniknęło ze strony publicznej. Treści **ukryte** widzi każdy zaufany i może je przywrócić. Treści po **opcji nuklearnej** (nielegalne, obrzydliwie obraźliwe) widzi tylko administracja — reszta widzi jedynie, że coś takiego było, kto to zrobił i dlaczego.

Status

Rodzaj

wszystko

wpisy i komentarze

Wpisy

3 pozycji na tablicy, strona 1 z 1

*  FUW-0012

opcja nuklearna

Treść widoczna tylko dla administracji. Ukrył/a: **dziekan** 12 września 2026 — powód: Treść niezgodna z prawem (demo).

 Zgłoś do NASK

* Mem, który był trochę za bardzo

ukryte

FUW-0011 · Memy · dodał/a student · akcja: **doktorant** 12 września 2026 — powód: Prosiła osoba na zdjęciu.

Pokaż treść

Przywróć

 Opcja nuklearna

 Zgłoś do NASK

Komentarze

pod **Energia jest zawsze zachowana. Wasza — niekoniecznie.** · autor student · akcja: **doktorant** 12 września 2026 — powód: Spam.

Ten komentarz został ukryty przez moderację.

Przywróć

 Opcja nuklearna

 Zgłoś do NASK

Stan	Publiczność	Zaufany	Staff	Head-admin
hidden	404	pełna treść + kto/kiedy/dlaczego	pełna treść	pełna treść
nuked 	404	stub: FUW-nnnn, aktor, powód	pełna treść	pełna treść
eskalowany 	404	404 (nawet dla zgłaszającego)	404	pełna treść + pakiet dowodowy
komentarz hidden	placeholder	treść	treść	treść
komentarz pod wpisem nuked	404	403 (należy do treści, której nie widzi)	treść	treść

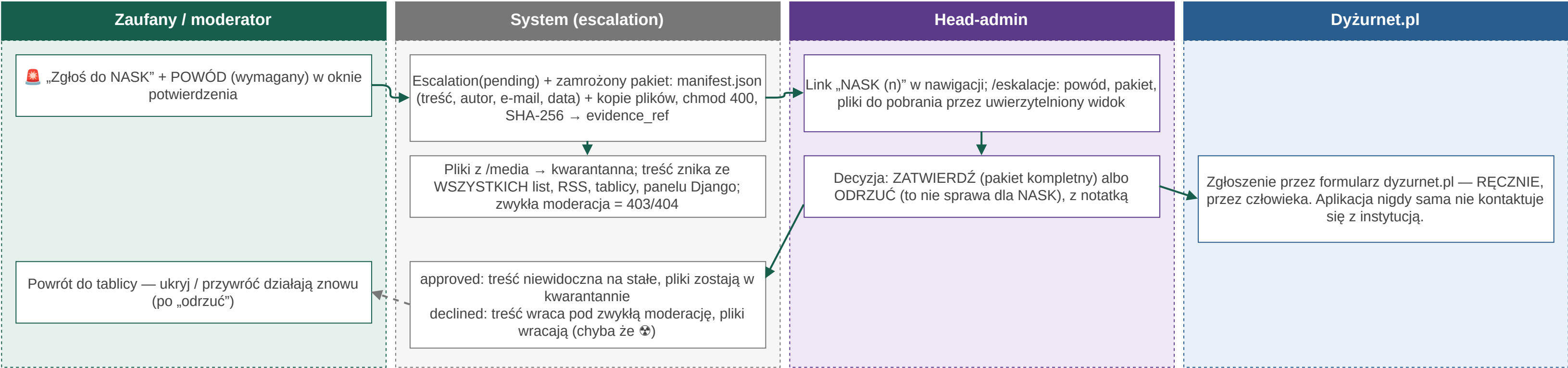
- **Jedna reguła, dwie postacie:** `can_see_post(user, post)` dla pojedynczego obiektu i `visible_posts_q(user)` dla querysetów — trzymane razem, żeby lista i szczegół nie mogły się rozjechać.
- **Serializery wygaszają, a nie widoki filtrują:** to, czego wywołujący nie może zobaczyć, jest wymazywane w serializerze (`body=""`, `author=""`), więc żaden nowy endpoint nie musi pamiętać o regule.
- **Opcja nuklearna:** powód obowiązkowy, zapis w dzienniku, pliki przenoszone do kwarantanny; cofnąć może tylko staff, a przywrócenie wraca do stanu sprzed ukrycia.
- **Nie ma kasowania.** Nagrobki, ukrycia, stuby — archiwum pamięta, że coś było, nawet gdy nie pokazuje co.
- **Panel Django** też respektuje eskalację (`escalation/adminmixin.py`) — poprawka z 16.09: wcześniej staff widział eskalowany wpis w `/admin/`.

/tablica — ukryte widzi każdy zaufany; nuklearne to dla niego tylko stub (numer, kto, kiedy, dlaczego)

fuw.lol — dokumentacja techniczna · stan na 17.09.2026 · źródło: docs/build_docs.py

8 / 15

Jedyny stan, w którym „zaufany” i nawet „staff” nic nie znaczą



- **Dlaczego dowody są zamrażane w tej samej transakcji:** autor może usunąć konto, moderator przywrócić wiadomość, plik może zostać podmieniony — pakiet ma przeżyć treść. Manifest i każdy plik mają SHA-256; katalog jest tylko do odczytu.
- **Fail-closed:** jeśli sprawdzenie „czy eskalowane?” rzuci wyjątek, odpowiedź brzmi „tak” — błąd w tym pliku ma powodować znikanie treści, nigdy jej ponowne pokazanie.
- **Brak wyroczeni:** zaufany, który sam eskalował, dostaje 404, nie „już eskalowane”; identyfikatory eskalacji są sekwencyjne, ale każdy nie-head-admin dostaje 403 zanim widok cokolwiek wyszuka.
- **Limit:** 10 eskalacji/dobę na konto. **Rejestr:** wiersz w bazie + linia w logu „security” (kompromitacja samej bazy nie zaciera śladu).

Zgłoszenia do NASK (Dyżurnet.pl)

Zaufany użytkownik lub moderator zgłasza treść nielegalną. Od tej chwili widzisz ją tylko Ty; kopia (treść, autor, pliki) jest zamrożona jako pakiet dowodowy z sumą SHA-256. **Zatwierdzenie** = pakiet jest kompletny, przekazujesz go ręcznie przez [dyzurnet.pl/zglos](#); treść zostaje niewidoczna na stałe. **Odrzucenie** = to nie sprawa dla NASK, treść wraca pod zwykłą moderację. Każda decyzja trafia do rejestru (baza + dziennik serwera).

Czekają na decyzjęZatwierdzone (zgłoszone)Odrzucone

Czekają na decyzję

2 pozycji

* #4 — wiadomość na czacie nr 5

czeka

zgłosił/a doktorant 16 września 2026

Powód zgłoszenia: Test: treść nielegalna (scenariusz e2e)

SHA-256 pakietu: f506a2b7843ce94baf04b82235c0a8fa1262801e4881ba0412eb881282802861

Zwiń materiał dowodowy

Zamrożono	2026-09-16 21:38:58.006893+00:00
Rodzaj	Message #5
Autor	Test Esk (gość)
Hash IP	7f3633980ae5c466df9b84fb9e5a76379dd1c9461197a27482f050e0fa756249
Pliki	brak

/eskalacje — pakiet dowodowy i dwie decyzje (widok tylko dla head-admina)

Pisze każdy, także bez konta — więc obrona jest tania i wielowarstwowa

Czat

Czat

stary dobry shoutbox — bez obrazków, z linkami i wzorami · Długie wiadomości zwijają się po 100 znakach

Nie musisz się logować. Bądź miły.

Nick

Anonim

TekstLaTeXPodgląd

Napisz coś. Linki i \$wzory\$ działają, obrazki nie.

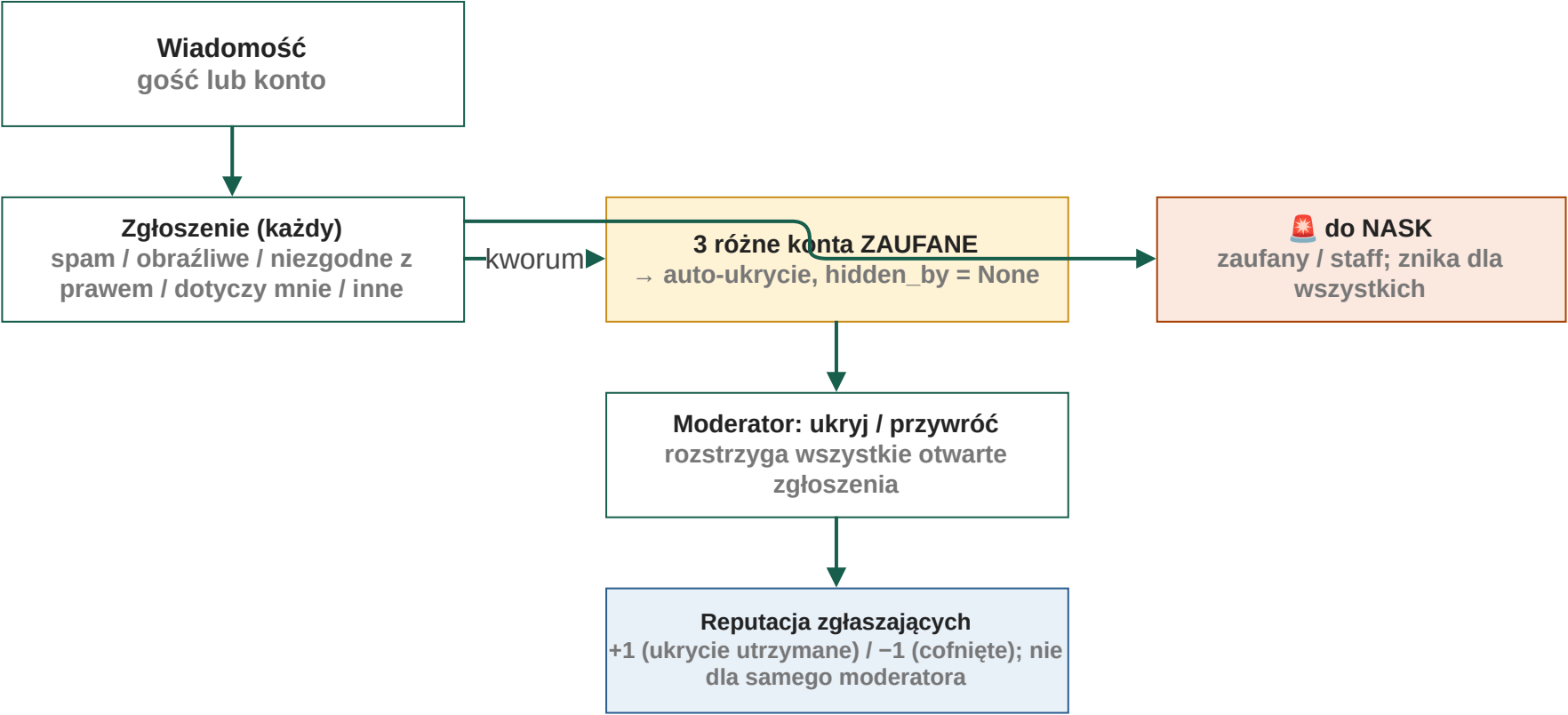
0 / 2048WyslijOdśwież

Kanał RSS

[15.09 12:00] Gel Anonim(gość) zgłoś

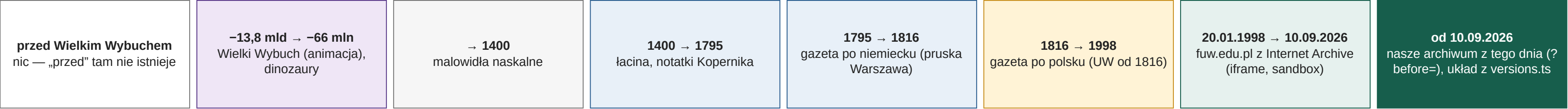
Uwazam, ze Jan Pawel II nie byl najwiekszym polakiem robakiem!!!!!!

/czat — nick gościa, tekst lub LaTeX, 2048 znaków, linki tak, obrazki nie



- **Warstwy obrony:** honeypot (pole website), limity 20/h gość i 60/h konto na adres IP, ≤ 5 linków, zakaz obrazków (![, <img, \includegraphics, data:image), nick gościa ≠ żaden login — także po NFKC, wielkości liter, kropkach i mieszaniu alfabetów (Piotr z cyrylicą i).
- **Zgłoszenia gości nigdy nie ukrywają same** — IP to nie tożsamość (NAT, wifi kampusu); liczą się tylko konta zaufane, każde raz.
- **Ukryj, nie kasuj:** hidden_by = None znaczy „zrobiły to zgłoszenia”, hidden_by = użytkownik — „moderator”. Moderator widzi liczbę otwartych zgłoszeń (▀ n); gość nie widzi, ilu innych już zgłosiło.
- **Adres IP** jest przechowywany tylko jako HMAC-SHA256 z osobną solą (FUWLOL_IP_SALT) — wystarcza, by poznać „to samo miejsce”, nie by je odtworzyć.
- **Stronicowanie po id** (before / since), bo strumień rośnie od góry; RSS z 50 ostatnich, bez eskalowanych.

Jedna czysta funkcja eraFor(date) i rejestr wersji układu strony



- **Dwa wejścia, bo jedno nie uniesie obu zadań:** `<input type=date>` dla dat, które przeglądarka przyjmie, i pole tekstowe dla reszty osi (-13800000000 nie mieści się w kalendarzu). Lista „Skoki” wpisuje wartość do właściwego pola.
- **Werdykt przed podróżą:** pod formularzem stoi „Trafisz do: ...” — użytkownik wie, co zobaczy, zanim kliknie „Jedź!”.
- **Internet Archive:** `/api/wayback/` rozwiązuje najbliższy zrzut po dacie (walidacja `\\d{{8}}`), stałe host i ścieżka — bez SSRF, timeout 8 s, cache 24 h); ramka ma sandbox bez allow-top-navigation i referrerpolicy=no-referrer.
- **versions.ts** to rejestr układów strony: każda przyszła przebudowa dopisuje wersję i ZOSTAWIA stary komponent — dzięki temu stara data renderuje stary wygląd.
- **Otwarte:** niemieckie i łacińskie epoki zachowują polskie tytuły wpisów (treść nie jest tłumaczona); wehikuł ma tylko strona główna.

Wehikuł czasu

Zobacz, jak wyglądała ta strona — albo poprzedniczka — w wybranym dniu.

Data

09/16/2026

Od 1900 do dziś.

Rok (ujemny = p.n.e., np. -13800000000)

np. 1543, -10000, -66000000

Można też podać 1543-05-24 albo 1543-05.

Skoki

— wybierz —

Gotowe przystanki na osi czasu.

Trafisz do: nasze archiwum

Jedź!

Formularz wehikułu na stronie głównej: data, rok, skoki, werdykt

Oś czasu

10 datowanych wpisów

lata 1990.

19981

lata 2000.

20011

20041

20071

20091

lata 2010.

20111

20152

/os-czasu — lata z liczbą wpisów, pogrupowane w dekady

fuw.lol — dokumentacja techniczna · stan na 17.09.2026 · źródło: docs/build_docs.py

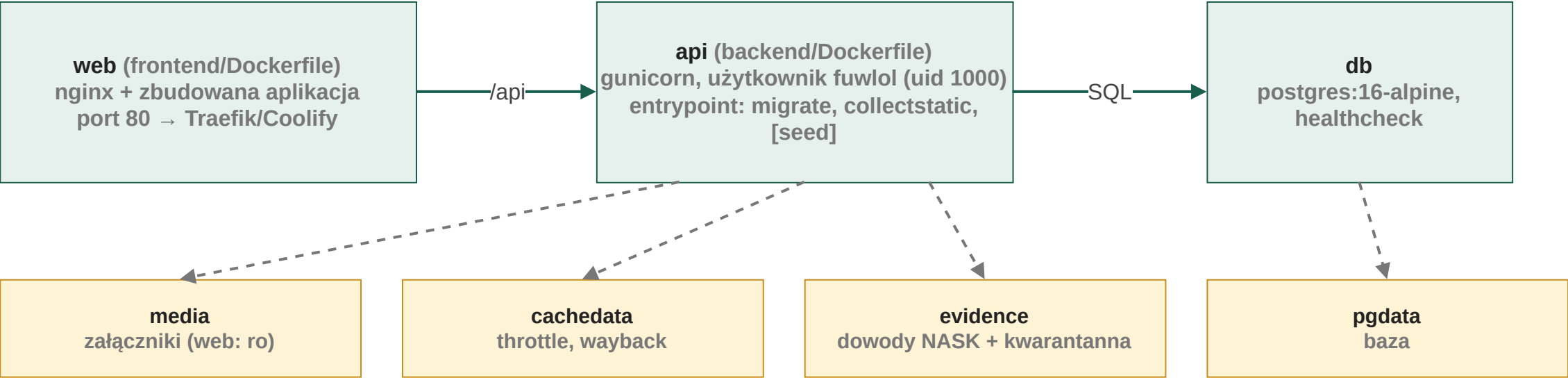
11 / 15

Trzy warstwy — i co zamknął przegląd z 16.09.2026

Pliki i treść	Renderowanie w przeglądarce	Sieć, tożsamość, limity
- Rozszerzenie z listy (bez SVG/HTML); decyzja po BAJTACH: Pillow musi zdekodować obraz (limit 40 Mpx z nagłówek — bomba dekompresyjna), PDF zaczyna się od %PDF, audio/wideo mają sygnaturę kontenera, tekst bez NUL. - Nazwa na dysku = UUID + rozszerzenie; nazwa oryginalna tylko do cytowania w treści. - JPEG/PNG/WebP zapisywane od nowa bez EXIF/ICC (GPS z telefonu); GIF i animowany WebP zostają (animacja to połowa memów). NOWE: pliki treści eskalowanej i nuklearnej przenoszone poza /media (kwarantanna) — zapamiętany URL → 404. - nginx: /media z nosniff, CSP „sandbox”, PDF/txt/tex jako attachment (nigdy nie renderują się na naszym originie).	- Markdown (marked) → DOMPurify z listą tagów/atributów; LaTeX.js → DOMPurify (bez <style>, formularzy, ramek); KaTeX z trust=false po sanityzacji. NOWE: obraz przeżywa sanityzację tylko, gdy jego src to URL naszego załącznika (albo blob: podglądu) — dotąd regex łapał tylko składnię , a i obrazy referencyjne przechodziły (piksel śledzący na każdego moderatora). NOWE: atrybut class niedozwolony w treści użytkownika (podszywanie się pod plakietki „Wyróżnione”, fałszywe komunikaty moderacji). - Każdy link: target=_blank, rel=nofollow noopener; javascript:/data: odrzucane. NOWE: CSP w nginx (img-src self blob: data:, frame-src web.archive.org, frame-ancestors self), X-Frame-Options, Referrer-Policy, Permissions-Policy; HSTS z Django dla /api i /admin.	NOWE: X-Forwarded-For czytany od prawej wg liczby zaufanych proxy (FUWLOL_PROXY_HOPS); CF-Connecting-IP tylko z FUWLOL_CLOUDFLARE=1. Dotąd pierwszy (kliencki) element sterował każdym limitem na IP. NOWE: throttle per akcja na ViewSecie był cichym no-opem (scope czytany z widoku) — post_create 30/h, escalate 10/d i nowy comment_create 60/h działają teraz naprawdę, z testem regresji. NOWE: logowanie limitowane także per login (10/min); walidatory haseł: długość, lista pospolitych, nie-numeryczne, niepodobne do loginu. NOWE: seed_demo nie resetuje haseł istniejących kont, a poza DEBUG losuje hasła i wypisuje je raz; obraz Dockera ma FUWLOL_DEBUG=0 i odmawia startu z domyślnym SECRET_KEY. NOWE: e-mail i notatka zgłaszającego tylko dla staff; review_note tylko dla autora; usunięcie komentarza i liczniki respektują eskalację; panel Django ukrywa treści eskalowane.

Przyjęte świadomie, nie zapomniane: token w localStorage (XSS = przejęcie sesji; CSP jest zabezpieczeniem drugiej linii, ciasteczko httpOnly to zmiana modelu auth) · jedno konto zaufane może eskalować (i zablokować) dowolną treść — 10/dobę, z pełnym rejestrem; to cena szybkiego działania przy CSAM · brak ClamAV (hosting go nie ma) — powiedziane, nie udawane · throttle liczy próby, nie porażki — pełna blokada konta po n nieudanych wymaga własnego mechanizmu · cache Cloudflare po kwarantannie trzeba wyczyścić ręcznie po URL-u · kwarantanna działa dla FileSystemStorage (jeden host) — S3 wymagałoby innej implementacji

docker-compose: trzy kontenery, cztery wolumeny, wszystko z FUWLOL_* w środowisku



- **Lokalnie:** `./setup.sh` (venv, zależności, migracje, seed, npm install) i `./run.sh` (API :8000, front :5173). Konta demo dziekan / doktorant / student, hasło fuwlo!123 — tylko w DEBUG.
- **Produkcja:** `cp .env.example .env`, uzupełnij sekrety, `docker compose up -d` albo Coolify z tym samym plikiem; szczegóły deploy/HETZNER.md.
- **Kopie:** pgdata + media + evidence. Bez evidence utrata pakietu = w bazie zostaje tylko hash.

Zmienna	Znaczenie	Domyślnie
FUWLOL_SECRET_KEY	klucz Django — wymagany, gdy FUWLOL_DEBUG=0 (inaczej start odmówi)	—
FUWLOL_DEBUG	1 lokalnie (run.sh); obraz Dockera ustawia 0	1 / 0 w obrazie
FUWLOL_ALLOWED_HOSTS / CSRF_ORIGINS / CORS_ORIGINS / SITE_URL	domena, pochodzenia, adres linków w mailach	z FUWLOL_DOMAIN
FUWLOL_TRUST_PROXY, FUWLOL_PROXY_HOPS, FUWLOL_CLOUDFLARE	prawdziwy adres klienta za proxy (config/middleware.py)	1, 2, 0
FUWLOL_IP_SALT	sól do hashy adresów (czat, dowody)	= SECRET_KEY
FUWLOL_MEDIA_ROOT / CACHE_DIR / EVIDENCE_ROOT	ścieżki wolumenów	/app/...
FUWLOL_EMAIL_*	SMTP na 587 (Hetzner blokuje 25) — mail weryfikacyjny	puste
FUWLOL_SEED_DEMO	1 = załóż treść demo przy starcie (wyłącz potem)	0

Co jest sprawdzane automatycznie, a co ręcznie w przeglądarce

135

testów backendu (Django/DRF), w tym 23 nowe po przeglądzie 16.09

0 / 0

błędów i ostrzeżeń svelte-check (238 plików)

34

kroków smoke testu w przeglądarce (frontend/e2e/smoke.mjs)

49

zrzutów z 4 ról × 2 szerokości — frontend/e2e/survey.mjs, 0 błędów konsoli

- **backend/.../tests.py**: uploady (bomba dekompresyjna, exe w .png, EXIF), uprawnienia (właściciel, staff), moderacja (hide/nuke/restore, stany, dziennik), zaufani (domeny, spoofing, token), czat (nick, limity, obrazki, zgłoszenia, kworum, reputacja), eskalacja (IDOR, „staff to nie head-admin”, zamrożenie, wyścig decyzji, dowody).
- **escalation/test_hardening.py** (nowe): panel Django, kwarantanna plików (eskalacja, nuke, odrzucenie przy nuke), wyrocznie (liczniki, zgłoszenie, usunięcie komentarza, parent), e-mail zgłaszającego, review_note, throttle wpisów/komentarzy/logowania per login, nicki-homoglify, sól hasha IP, seed nie resetuje hasła.
- **Uruchomienie**: `cd backend && ../.venv/bin/python manage.py test` · `cd frontend && npm run check && npm run build` · przy działających serwerach `npm run e2e` i `node e2e/survey.mjs`.
- **Czego testy nie łapią**: wyglądu — stąd survey.mjs i oglądanie zrzutów (tak znaleziono zdublowane wpisy na stronie głównej i szare placeholderzy na telefonie); realnej konfiguracji proxy na serwerze (FUWLOL_PROXY_HOPS trzeba sprawdzić raz na produkcji, np. logując REMOTE_ADDR).

Przeglądaj archiwum

Szukaj

tytuł, treść, tag, osoba...

Kategoria

— wszystkie —

Osoba

— ktokolwiek —

Tag

— dowolny —

Format

— dowolny —

Rok od

1998

Rok do

2026

Sortuj

Najnowsze

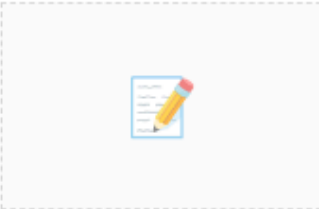
Filtruj

Wyczyść

Wyniki

9 wpisów

* Egzamin, na którym odpowiedź brzmiała 42

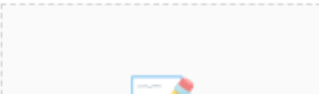


Treść zadania w LaTeX-u — kliknij, żeby zobaczyć. | Więcej

FUW-0009

Legendarne zadania · ok. 2015 · prof. Helena Hamiltonian · 2 reakcji · 2 kom. · Wyróżnione

* Zadanie 3 z kolokwium, którego nikt nie rozwiązał



Treść zadania w LaTeX-u — kliknij, żeby zobaczyć. | Więcej

FUW-0008

Legendarne zadania · 2011 · dr Kwant Niepewny · 2 reakcji

/przegladaaj — filtry w URL-u, więc wyszukiwanie jest linkiem

fuw.lol — dokumentacja techniczna · stan na 17.09.2026 · źródło: docs/build_docs.py

14 / 15

Trzy ścieżki użytkownika, ich tarcia i co warto zrobić następne

Gość: „szukam tego mema z kolokwium”	Student: „dodam wpis”	Zaufany / staff: „coś tu nie powinno wisieć”
- Strona główna → Przeglądaj (filtry w URL) → wpis → reakcja wymaga konta. Tarcie: na telefonie filtry zajmują cały ekran zanim pojawi się pierwszy wynik. Tarcie: lista osób i oś czasu to jeden klik dalej niż wyszukiwarka — mało kto tam trafia. Zrobione: placeholderzy bez obrazka znikają na telefonie; strona główna nie powtarza wyróżnionych. Rekomendacja: zwinięte filtry na telefonie („Filtruj (2)”), wyszukiwanie w nagłówku zamiast lupy prowadzącej do /przeglądaj.	- Rejestracja → /dodaj (dane, pliki, treść z podglądem) → pending → /moje pokazuje status. Tarcie: długi formularz bez autozapisu — odświeżenie strony gubi treść. Tarcie: o odrzuceniu autor dowiaduje się tylko, jeśli sam zajrzy do /moje; nie ma maila ani znacznika „nowe”. Tarcie: brak resetu hasła — zablokowane konto to koniec. Rekomendacja: szkic w localStorage; mail/„dzwonek” o decyzji; reset hasła (SMTP już jest do weryfikacji).	- Wpis lub czat → Ukryj (dialog z powodem) → tablica; opcja nuklearna z powodem; NASK z powodem → head-admin. Zrobione: okna potwierdzenia zamiast prompt(); NASK odróżniony wizualnie; strona /eskalacje z dowodami i dwiema decyzjami; licznik „NASK (n)” w nawigacji. Tarcie: tablica i kolejka nie powiadamiają — moderator musi zaglądać; head-admin o eskalacji dowiaduje się dopiero po zalogowaniu. Tarcie: przy 12 linkach nawigacja staff zawija się w dwie linie. Rekomendacja: mail do head-admina przy eskalacji (najpilniejsze), dzienny mail „n w kolejce”, grupa „Moderacja ▼” w nawigacji.

Kolejność proponowana: 1) mail o eskalacji do head-admina i reset hasła (ten sam SMTP) · 2) autozapis szkicu i powiadomienie o decyzji · 3) zwinięte filtry i wyszukiwanie w nagłówku na telefonie · 4) grupa „Moderacja” w nawigacji · 5) research rynkowy (docs/research-brief-gemini.md) zanim dojdą kolejne funkcje — najpierw sprawdzić, skąd studenci naprawdę przyniesliby treść.